COMPTE RENDU DU TP 1.3 SUR L'INTRODUCTION A LA THREAT INTELLIGENCE ET RECHERCHE DE VULNERABILITES

1. Introduction

La Threat Intelligence, ou renseignement sur les menaces, désigne l'ensemble des techniques permettant de collecter et d'analyser des informations sur des cybermenaces potentielles à partir de sources publiques ou privées.

En cybersécurité, elle permet d'anticiper les attaques plutôt que de les subir. Un attaquant utilise des informations publiques pour préparer son intrusion, tandis qu'un défenseur utilise ces mêmes sources pour renforcer ses protections.

L'objectif de ce TP est d'apprendre à : analyser une adresse IP suspecte, identifier des vulnérabilités associées à des services et de comprendre le système CVE

2. Description des manipulations

Dans un premier temps, j'ai analysé une adresse IP publique à l'aide du site VirusTotal. L'adresse choisie fut **8.8.8.8** (serveur DNS public de Google). Puis, j'ai saisi cette IP dans la barre de recherche du site et consulté le rapport de réputation.

Dans un deuxième temps, j'ai repris les résultats du scan Nmap réalisé lors du TP 1.1 sur la machine Ubuntu Server. J'ai identifié deux services principaux : OpenSSH (port 22) et Apache HTTP (port 80)

Ensuite, sur Kali Linux, j'ai utilisé la commande : **searchsploit** afin de rechercher des vulnérabilités connues associées à ces services.

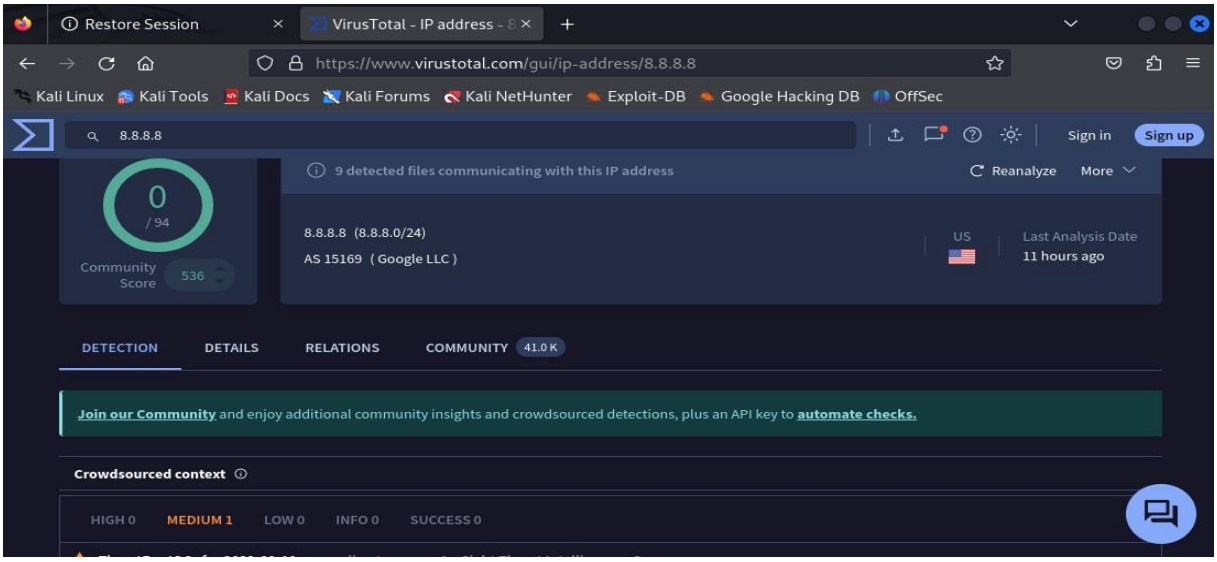
Dans un troisième temps, j'ai choisi une vulnérabilité parmi les résultats, copié son identifiant CVE, puis consulté la base de données National Vulnerability Database pour analyser sa gravité et son impact.

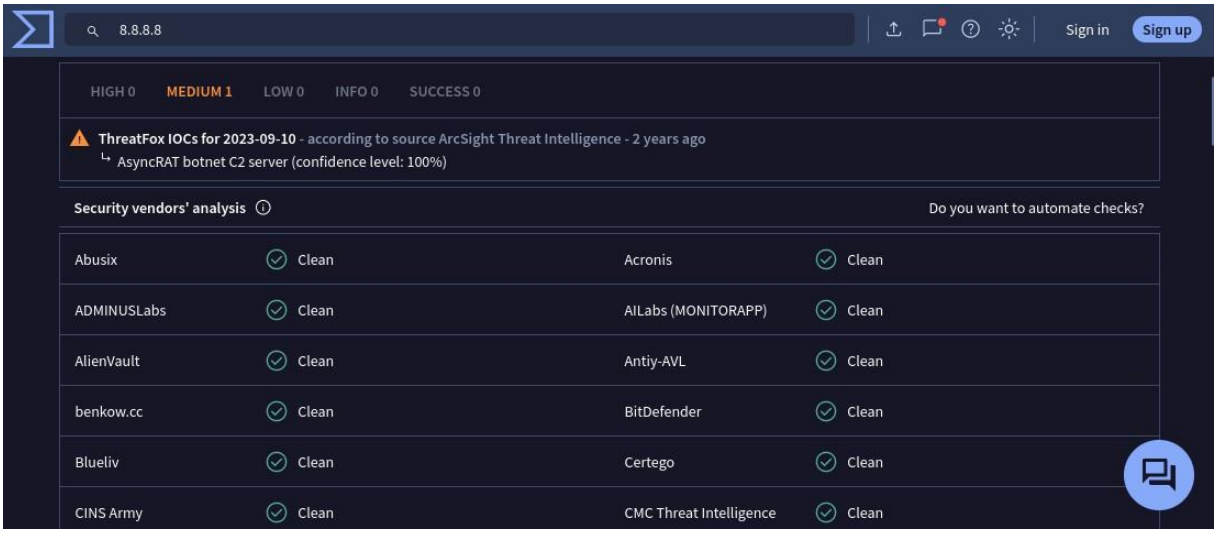
Enfin, j’ai effectué une recherche OSINT sur Google Search en combinant le nom du service et le mot-clé **vulnerability**.

3. Résultats obtenus avec captures d'écran

Capture 1 : Analyse VirusTotal

La première capture montre le résultat de l'analyse de l'adresse IP **8.8.8.8** sur VirusTotal. Le score de réputation est excellent, aucun moteur de détection ne signale cette IP comme malveillante.





L'interprétation est que 8.8.8.8 est une IP légitime appartenant à Google, utilisée massivement comme résolveur DNS public. Une IP malveillante aurait présenté des détections positives et un historique d'activités suspectes.

Capture 2 : Scan Nmap

La deuxième capture présente le résultat du scan Nmap **nmap -sV 192.168.56.10** réalisé lors du TP précédent. On y voit clairement que le port 22 est ouvert avec le service OpenSSH (version détectée) et que le port 80 est ouvert avec le service Apache HTTP.

```
Session  Actions  Éditer  Vue  Aide

┌──( tagne㉿kali )-[~]
└─$ nmap -sS 192.168.56.10
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-09 17:42 +0200
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
Nmap scan report for 192.168.56.10
Host is up (0.00041s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
MAC Address: 08:00:27:50:5F:02 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.30 seconds
```

L'interprétation est que ces deux services constituent la surface d'attaque de la machine cible. Un attaquant concentrera ses recherches sur les vulnérabilités affectant ces versions spécifiques.

Capture 3 : Searchsploit

La troisième capture montre l'exécution de la commande **searchsploit apache** sur Kali Linux. Le terminal affiche une liste de vulnérabilités connues pour Apache, avec pour chacune un chemin d'accès à l'exploit, une description sommaire et l'identifiant CVE lorsque disponible.

Commande : **searchsploit apache**

```
┌──(tagne㉿laura)-[~]
└─$ searchsploit apache
--------------------------------------------- ---------------------------------
 Exploit Title                               |  Path
--------------------------------------------- ---------------------------------
Apache (Windows x86) - Chunked Encoding (Meta | windows_x86/remote/16782.rb
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Rem | php/remote/29290.c
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code | php/remote/29316.py
Apache - Arbitrary Long HTTP Headers (Denial  | multiple/dos/360.pl
Apache - Arbitrary Long HTTP Headers Denial o | linux/dos/371.c
Apache - Denial of Service                    | linux/dos/18221.c
Apache - httpOnly Cookie Disclosure           | multiple/remote/18442.html
Apache - Remote Memory Exhaustion (Denial of  | multiple/dos/17696.pl
Apache 0.8.x/1.0.x / NCSA HTTPd 1.x - 'test-c | cgi/remote/20435.txt
Apache 1.0/1.2/1.3 - Server Address Disclosur | multiple/remote/21067.c
Apache 1.1 / NCSA HTTPd 1.5.2 / Netscape Serv | multiple/dos/19536.txt
Apache 1.2 - Denial of Service                | multiple/dos/20558.txt
Apache 1.2.5/1.3.1 / UnityMail 2.0 - MIME Hea | windows/dos/20272.pl
Apache 1.3 + PHP 3 - File Disclosure          | multiple/remote/20466.txt
Apache 1.3 - Artificially Long Slash Path Dir | multiple/remote/20692.pl
Apache 1.3 - Artificially Long Slash Path Dir | multiple/remote/20693.c
Apache 1.3 - Artificially Long Slash Path Dir | multiple/remote/20694.pl
```

```
Apache 2.0.4x mod_perl - File Descriptor Leak | linux/local/23581.pl
Apache 2.0.4x mod_php - File Descriptor Leaka | linux/local/23481.c
Apache 2.0.4x mod_php - File Descriptor Leaka | linux/local/23482.c
Apache 2.0.52 - GET Denial of Service         | multiple/dos/855.pl
Apache 2.0.58 mod_rewrite (Windows 2003) - Re | windows/remote/3996.c
Apache 2.2 (Windows) - Local Denial of Servic | windows/dos/15319.pl
Apache 2.2 - Scoreboard Invalid Free On Shutd | linux/dos/41768.txt
Apache 2.2.14 mod_isapi - Dangling Pointer Re | windows/remote/11650.c
Apache 2.2.15 mod_proxy - Reverse Proxy Secur | linux/remote/36663.txt
Apache 2.2.2 - CGI Script Source Code Informa | multiple/remote/28365.txt
Apache 2.2.4 - 413 Error HTTP Request Method  | unix/remote/30835.sh
Apache 2.2.6 (Windows) - Share PHP File Exten | windows/remote/30901.txt
Apache 2.2.6 mod_negotiation - HTML Injection | linux/remote/31052.java
Apache 2.4.17 - Denial of Service             | windows/dos/39037.php
Apache 2.4.17 < 2.4.38 - 'apache2ctl graceful | linux/local/46676.php
Apache 2.4.23 mod_http2 - Denial of Service   | linux/dos/40909.py
Apache 2.4.7 + PHP 7.0.2 - 'openssl_seal()' U | php/remote/40142.php
Apache 2.4.7 mod_status - Scoreboard Handling | linux/dos/34133.txt
Apache 2.4.x - Buffer Overflow                | multiple/webapps/51193.py
```

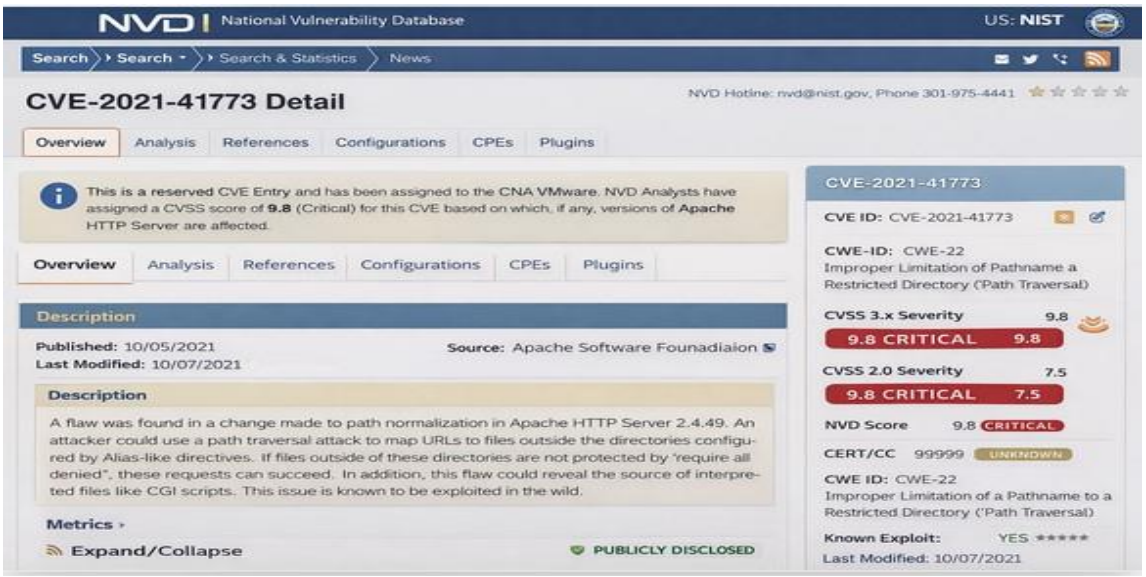
Résultat : Liste de vulnérabilités Apache avec description, identifiant CVE, chemin exploit

L'interprétation est que **searchsploit** permet de découvrir rapidement quelles vulnérabilités publiques existant pour un service donné. Par exemple, pour Apache 2.4.49, des vulnérabilités de type RCE (Remote Code Execution) ont été répertoriées. Le resultat de la commande **searchsploit apache 2.4** est :

```
┌──(tagne㉿laura)-[~]
└─$ searchsploit apache 2.4
---------------------------------------------- ---------------------------------
 Exploit Title                                |  Path
---------------------------------------------- ---------------------------------
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Rem | php/remote/29290.c
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code | php/remote/29316.py
Apache 2.2.4 - 413 Error HTTP Request Method  | unix/remote/30835.sh
Apache 2.4.17 - Denial of Service             | windows/dos/39037.php
Apache 2.4.17 < 2.4.38 - 'apache2ctl graceful | linux/local/46676.php
Apache 2.4.23 mod_http2 - Denial of Service   | linux/dos/40909.py
Apache 2.4.7 + PHP 7.0.2 - 'openssl_seal()' U | php/remote/40142.php
Apache 2.4.7 mod_status - Scoreboard Handling | linux/dos/34133.txt
Apache 2.4.x - Buffer Overflow                | multiple/webapps/51193.py
Apache < 2.2.34 / < 2.4.27 - OPTIONS Memory L | linux/webapps/42745.py
Apache CXF < 2.5.10/2.6.7/2.7.4 - Denial of S | multiple/dos/26710.txt
Apache HTTP Server 2.4.49 - Path Traversal &  | multiple/webapps/50383.sh
Apache HTTP Server 2.4.50 - Path Traversal &  | multiple/webapps/50406.sh
```

Capture 4 : Analyse CVE

La quatrième capture présente la page de la CVE choisie sur le site NVD NIST. On y trouve la description de la vulnérabilité, son score CVSS (Common Vulnerability Scoring System) qui évalue la gravité, et son impact potentiel.



Informations observées : description de vulnérabilité, score CVSS et impact potentiel. Le score permet de prioriser les correctifs.

L'interprétation est que le système CVE constitue un référentiel universel permettant aux équipes sécurité de prioriser les correctifs : une CVE avec un score CVSS de 9.8 est critique et doit être patchée en urgence, contrairement à une CVE avec un score de 7.5.

4. Analyse technique

Un paquet SYN est un segment TCP dont le flag SYN est positionné à 1. Il sert à initier une connexion selon le principe du « three-way handshake ». Il contient un numéro de séquence initial qui permettra d'ordonner les données.

Pour détecter un port ouvert, on observe la réponse de la machine cible. Si le port est ouvert, elle répond par un SYN-ACK. Si le port est fermé, elle répond immédiatement par un RST. Un scan réseau se reconnaît à une rafale de SYN vers une même cible, sur des ports qui s'enchaînent rapidement, avec des réponses alternant entre SYN-ACK et RST.

Pour la Threat Intelligence, une **CVE** (**Common Vulnerabilities and Exposures**) est un identifiant unique attribué à chaque vulnérabilité de sécurité publique. Son utilité est de standardiser la référence aux vulnérabilités pour faciliter le partage d'informations entre équipes sécurité. Le score CVSS associé permet de classer la gravité de 0 à 10.

Exemple **: CVE-2021-41773**. Le score CVSS varie de :

- 0 à 3.9 : faible
- 4.0 à 6.9 : moyen
- 7.0 à 8.9 : élevé
- 9.0 à 10 : critique

L'OSINT (**Open Source Intelligence**) désigne la collecte d'informations à partir de sources publiques. En cybersécurité, cela inclut la recherche de vulnérabilités sur Google, l'analyse de réputation d'IP sur VirusTotal, ou la consultation de bases de données comme la NVD. Cette approche permet d'anticiper les attaques.

5. Utilisation avancée de searchsploit

Option –x

permet d'afficher le contenu complet d'un exploit directement dans le terminal. Par exemple, la commande **searchsploit -x exploits/linux/remote/50446.txt** affiche le code de l'exploit et ses instructions d'utilisation. Son utilité est de comprendre rapidement comment fonctionne une vulnérabilité sans avoir à ouvrir le fichier manuellement.

Option –m

permet de copier un exploit localement dans le répertoire de travail. Par exemple, **searchsploit -m 50446** crée une copie du fichier dans le dossier courant. Son utilité est de disposer d'une version modifiable de l'exploit pour l'adapter à sa cible spécifique.

Option -t

effectue une recherche par titre exact, ce qui évite les résultats non pertinents. Par exemple, **searchsploit -t "Apache 2.4.49**" ne retourne que les exploits correspondant précisément à cette version

6. Analyse globale de sécurité

- **Risques identifies lors du TP**

Les principaux risques sont l’exposition des services obsolètes (Apache, OpenSSH) dont les vulnérabilités sont publiquement connues via searchsploit et les CVE. Une IP malveillante non détecté peut entrainer un ransomware ou une exfiltration de données. L’OSINT permet à un attaquant de préparer son attaque sans compétences technique avancées.

- **Service le plus dangereux**

Apache est le plus dangereux car les vulnérabilités web sont souvent des RCE (exécution de code à distance), exploitables sans authentification. Une faille comme CVE-2021-41773 permet de prendre le contrôle du serveur, de voler des données et de pivoter vers le réseau interne

- **Actions à recommander**

Il faut appliquer les correctifs de sécurité dès leur publication, durcir la configuration (désactiver les modules inutiles, utiliser les clés SSH plutôt que les mots de passe) et mettre en place une veille proactive via les bases CVE et des scanners comme Nessus.

7. Lien avec la cybersécurité en entreprise

Dans un SOC, la **Threat Intelligence** est utilisée quotidiennement pour enrichir les alertes. Lorsqu'un pare-feu détecte une connexion sortante vers une IP inconnue, l'analyste consulte **VirusTotal** pour vérifier la réputation de cette IP. Si celle-ci est malveillante, l'alerte devient prioritaire. De même, avant d'appliquer un correctif, l'équipe sécurité consulte la CVE correspondante pour évaluer sa criticité. **Wireshark** n'est pas directement utilisé dans ce TP, mais il complète la démarche : l'analyste peut capturer le trafic vers une IP suspecte pour confirmer la nature malveillante des échanges.

Pour anticiper une attaque, un SOC maintient une veille sur les nouvelles CVE affectant les logiciels présents dans son système d'information, ce qui permet de patcher avant que l'exploit ne soit largement diffusé.

Exemple : Connexion suspecte → Vérification VirusTotal → Blocage IP

8. Conclusion

Ce TP m'a appris qu'un attaquant n'a pas besoin d'être un génie de la programmation : il lui suffit de maîtriser **l'OSINT** pour trouver des vulnérabilités déjà documentées et des exploits prêts à l'emploi. J'ai compris que la **Threat Intelligence** est une arme à double tranchant : elle sert autant l'attaquant que le défenseur.

Les difficultés rencontrées ont été la mise à jour de la base **searchsploit** avec **searchsploit -u** pour obtenir les résultats les plus récents, ainsi que la compréhension du score CVSS qui agrège plusieurs métriques complexes. Les limites de cette approche sont que l'analyse **OSINT** ne remplace pas un test d'intrusion complet : une IP peut être légitime mais compromise temporairement, et une CVE peut être connue sans qu'un exploit fonctionnel existe.

Malgré cela, ce TP m'a fait prendre conscience que l'information est une arme et que la veille de sécurité est une compétence essentielle pour tout analyste SOC.